

Cyber Tabletop Exercise

DDoS Against Online and Mobile Banking

Exercise type: Facilitated tabletop exercise

Audience: Executive, operational, and technical stakeholders

Suggested duration: 90 minutes

Scenario source: Derived from uploaded STIX bundle

Classification: Internal use for exercise facilitation

1. Exercise Overview

Scenario summary

A banking organization providing consumer online and mobile banking services experiences a high-volume denial-of-service event against its public digital banking channels during a peak usage window. Customers begin reporting login failures and intermittent service availability. The bank must manage technical response, business continuity, customer communications, service prioritization, and executive decision-making while determining whether to activate external DDoS mitigation capabilities and failover options.

Core theme

This exercise tests whether the organization can coordinate cyber, technology, business, and communications functions during a public-facing outage that directly affects customer trust and service availability.

2. Objectives

By the end of the exercise, participants should be able to:

1. Assess and escalate a major disruption affecting online and mobile banking services.
2. Coordinate technical response activities for a public-facing DDoS event.
3. Prioritize critical customer services and continuity decisions under pressure.
4. Manage internal and external communications in a way that reduces panic and misinformation.
5. Evaluate when to invoke contracted mitigation services such as scrubbing, CDN, filtering, and failover.
6. Align executive, operational, and technical decisions during a fast-moving outage.
7. Define recovery, service restoration, and post-incident reporting priorities.

Success criteria

- Major incident and crisis governance are activated at the right time.

- Critical digital banking journeys are identified and prioritized.
 - Customer messaging is timely, accurate, and consistent across channels.
 - DDoS mitigation and failover decisions are made with clear ownership.
 - Technical, operational, legal, and communications stakeholders remain synchronized.
 - Recovery actions and after-action priorities are clearly defined.
-

3. Scope and Assumptions

In scope

- Online banking portal availability
- Mobile banking access and authentication
- Customer login and account access issues
- Public status page availability
- DDoS mitigation activation and traffic rerouting
- Internal escalation and crisis-management coordination
- Customer communications and reputation management
- Recovery, restoration, and lessons learned

Out of scope

- Full packet-level forensic analysis
- Malware reverse engineering
- Core banking compromise not indicated in the scenario
- Third-party provider internal remediation beyond exercise injects

Assumptions

- The organization has an existing incident-management process.
 - DDoS mitigation services or equivalent provider options are contractually available.
 - Alternate customer service channels exist, such as contact center or branch escalation.
 - Participants respond based on current roles, responsibilities, and documented processes.
 - No evidence of customer data theft is initially known.
-

4. Suggested Participant Roles

Executive / strategic

- Crisis lead / executive management
- Business operations lead
- Digital banking leadership
- Corporate communications / media lead
- Legal, compliance, and privacy representative

Operational

- Incident commander
- Security Operations Center lead
- IT operations / infrastructure lead
- Customer support / contact center lead
- Vendor management lead

Technical

- Network / DDoS mitigation lead
- Application owner for online and mobile banking
- Authentication / identity lead
- Monitoring and logging lead
- Platform resilience / failover lead

Exercise support

- Facilitator
 - Scribe
 - Observer(s)
-

5. Rules of Engagement

- This is a no-fault discussion exercise.
 - There are no perfect answers; the goal is to surface decision points, dependencies, and improvement opportunities.
 - Treat the scenario as realistic and current.
 - Participants should explain decisions, ownership, timing, and communications.
 - Real-world incidents take priority.
 - The facilitator may introduce assumptions or prompts if discussion stalls.
-

6. Initial Situation Brief

The organization delivers consumer online and mobile banking through a public-facing digital platform supporting authentication, account access, and customer-initiated transactions. During a peak usage window, customers begin reporting widespread failures to access digital banking services. At the same time, the bank's public status page becomes intermittently unavailable, increasing confusion and frustration.

Early indicators suggest a high-volume denial-of-service event affecting the bank's public banking channels. Leadership must quickly determine how to classify the incident, which services to prioritize, whether to invoke external mitigation providers, and how much information to share with customers, regulators, and internal stakeholders.

7. Exercise Timeline and Injects

Inject 1 – Customer login failures rise sharply

Exercise time: 09:00

Stage: Initial detection

Inject

Customers report widespread failures to access online banking and mobile services. The bank's status page becomes intermittently unavailable. Social media complaints increase rapidly and the contact center reports a spike in calls.

What participants know

- Online banking and mobile services are unavailable or degraded for many customers.
- The public status page is unstable.
- Customer frustration is becoming visible externally.
- Root cause has not yet been confirmed.

Discussion questions

- How is the incident triaged, classified, and escalated?
- Who owns the initial incident command function?
- What monitoring or validation steps confirm DDoS versus general service degradation?
- Which customer journeys must be preserved first: login, balance viewing, password reset, transfer initiation, or service-status communications?
- What immediate internal notifications are required?
- What customer-facing holding statement should be prepared?

Expected actions

- Open and classify a major incident.
- Stand up an incident coordination bridge.
- Notify executive, cyber, technology, customer support, and communications stakeholders.
- Increase monitoring on public-facing services and authentication failures.
- Prepare initial customer communications.

Facilitator notes

Encourage participants to distinguish between technical diagnosis and business-impact assessment. Test whether the team can quickly identify customer trust and reputation risk alongside service availability.

Inject 2 – Reassurance versus restoration decisions

Exercise time: 10:30

Stage: Active disruption and response prioritization

Inject

Leadership must decide how much information to release publicly, which services to prioritize, and whether to invoke external scrubbing, CDN, or traffic-filtering providers. Technical teams advise that mitigation options are available but may require controlled failover and temporary service degradation for nonessential functions.

What participants know

- The incident is affecting customer access at scale.
- Senior leaders must balance technical restoration, customer reassurance, and reputational protection.
- External mitigation services can be engaged, but tradeoffs exist.
- Customer support channels are under strain.

Discussion questions

- When should external scrubbing or filtering services be activated?
- What services should be prioritized for continuity, and which can be temporarily degraded?
- Who approves failover decisions and customer-facing messaging?
- How should communications differ for customers, front-line support, executives, and regulators?
- What guidance should be given to branches and contact center teams?
- How will misinformation or speculation on social media be handled?

Decision points

- Invoke external DDoS mitigation now or continue internal containment first?
- Preserve core account access only, or maintain a broader service set with higher risk?
- Publish detailed status information or a limited holding statement?

Expected actions

- Engage contracted DDoS mitigation or scrubbing capability.
- Prioritize critical banking functionality.
- Defer or rate-limit nonessential services if required.
- Issue approved customer and employee communications.
- Coordinate with vendor-management and resilience teams.

Facilitator notes

Push participants to articulate who owns the decision to trade breadth of service for stability. Surface conflicts between communications transparency and technical uncertainty.

Inject 3 – Stabilization with uncertain recovery timeline

Exercise time: 12:00

Stage: Partial stabilization

Inject

Mitigation measures appear to reduce the worst of the disruption, but service performance remains inconsistent. Customer complaints decline slightly, though transaction delays and authentication instability continue. Leadership does not yet have a confident estimate for full restoration.

What participants know

- Some mitigation appears effective.
- The customer impact remains significant.
- Full restoration timing is uncertain.
- Senior leadership is asking for a revised operating picture and recovery timeline.

Discussion questions

- What business services should now be prioritized for partial restoration?
- What criteria determine that customer impact is acceptable enough to move from crisis mode to controlled recovery?
- Are manual or alternate customer-service workarounds sufficient if disruption continues?
- What executive updates and communication cadence should be used?
- What external stakeholders, if any, should be briefed at this stage?

Expected actions

- Reassess service priorities and incident severity.
- Publish updated internal and external status messaging.
- Track business, reputational, and customer-service impacts.
- Validate resilience measures and workarounds.
- Begin planning for structured recovery and post-incident review.

Facilitator notes

This inject tests whether participants can manage uncertainty without losing discipline. Ask how they avoid overpromising on restoration timing.

Inject 4 – Service restoration and recovery

Exercise time: 14:00

Stage: Recovery and closure

Inject

Traffic conditions normalize and digital banking services are restored to expected performance. The major disruption is considered contained. Leadership must now manage post-incident reporting, customer reassurance, review of service prioritization decisions, and lessons learned.

What participants know

- Online and mobile banking access has returned to normal.
- The immediate disruption has been contained.
- Customer confidence and post-incident communications remain important.
- A post-incident review is required.

Discussion questions

- What are the conditions for formally standing down the crisis structure?
- What customer follow-up communications are required?
- Were the chosen workarounds and prioritization decisions adequate?
- What regulatory, legal, or internal reporting should be initiated?
- What metrics and evidence should be preserved for lessons learned and future planning?

Expected actions

- Confirm service restoration and controlled incident closure.
- Communicate recovery status to customers and internal stakeholders.
- Preserve logs, timelines, decisions, and communications artifacts.
- Launch after-action review and improvement planning.
- Review vendor performance and contractual mitigation effectiveness.

Facilitator notes

Drive discussion toward measurable improvements, not just narrative closure. Ask what would change if a similar event lasted longer or recurred within days.

8. Business and Technical Impacts to Explore

Business impacts

- Customer inability to access funds and account information
- Increased contact center volume and service backlog
- Reputation damage and loss of customer confidence
- Potential transaction delays and complaints
- Executive and board-level visibility

Technical impacts

- Degraded availability of internet-facing banking services
 - Authentication instability or increased login failures
 - Status page disruption reducing transparency
 - Elevated infrastructure load and potential failover stress
 - Monitoring and observability challenges during peak attack traffic
-

9. Facilitator Prompts

Use these prompts if discussion slows:

- What thresholds distinguish a service outage from a cyber crisis?
 - Who can authorize mitigation-provider activation after hours?
 - How will you prioritize services if all of them cannot be restored at once?
 - What customer messages help reduce panic without creating false certainty?
 - How does the team ensure executives receive concise, decision-ready updates?
 - What evidence should be preserved even if this appears to be “only” an availability incident?
-

10. Debrief and Lessons Learned

Debrief questions

- What worked well in the first 30 minutes?
- Where were roles, ownership, or escalation unclear?
- Were communications timely and appropriately tailored?
- Were service-prioritization decisions risk-based and realistic?
- Did technical and business teams share a common operating picture?
- What dependencies on third parties were exposed?
- What would need to improve before running this exercise again?

Improvement themes

- DDoS runbooks and escalation thresholds
 - Service-priority definitions for digital banking
 - Customer communication templates and approval flows
 - Status page resilience and alternative notification channels
 - Vendor engagement and mitigation playbooks
 - Metrics, logging, and executive reporting discipline
-

11. MITRE ATT&CK Mapping

The scenario most closely aligns with the following ATT&CK technique set:

Tactic: Impact

- **T1498 – Network Denial of Service**
Reflects the high-volume disruption of public-facing online and mobile banking access.
- **T1498.001 – Direct Network Flood**
Applicable where attack traffic directly floods exposed banking services.

- **T1498.002 – Reflection Amplification**

Potentially relevant if the DDoS campaign uses reflected or amplified traffic through third-party infrastructure.

- **T1499 – Endpoint Denial of Service**

Relevant if specific application endpoints or access components are overwhelmed, even where full infrastructure collapse does not occur.

Tactic: Resource Development / Infrastructure Support (contextual)

- Adversaries conducting DDoS often leverage botnet or rented infrastructure; while not explicitly described in the STIX bundle, facilitators may reference external attack infrastructure as a plausible supporting assumption.

Defensive implications for participants

- Early recognition of availability-focused attacks as cyber incidents
- Clear thresholds for activating DDoS mitigation providers
- Preservation of telemetry needed to characterize attack type, duration, and targets
- Coordination between cyber response, digital operations, customer support, and communications teams

12. Appendix – Source Scenario Elements Interpreted from STIX

- Target organization: Banking organization in the financial-services sector
- Target infrastructure: Online banking and mobile access platform
- Attack pattern: Flood public banking channels to deny customer access
- Incident: DDoS against online and mobile banking
- Course of action: Invoke DDoS traffic scrubbing and failover
- Course of action: Customer channel outage communication plan
- Notes incorporated into injects:
 - Customer login failures rise sharply
 - Customer reassurance versus restoration focus

End of exercise document